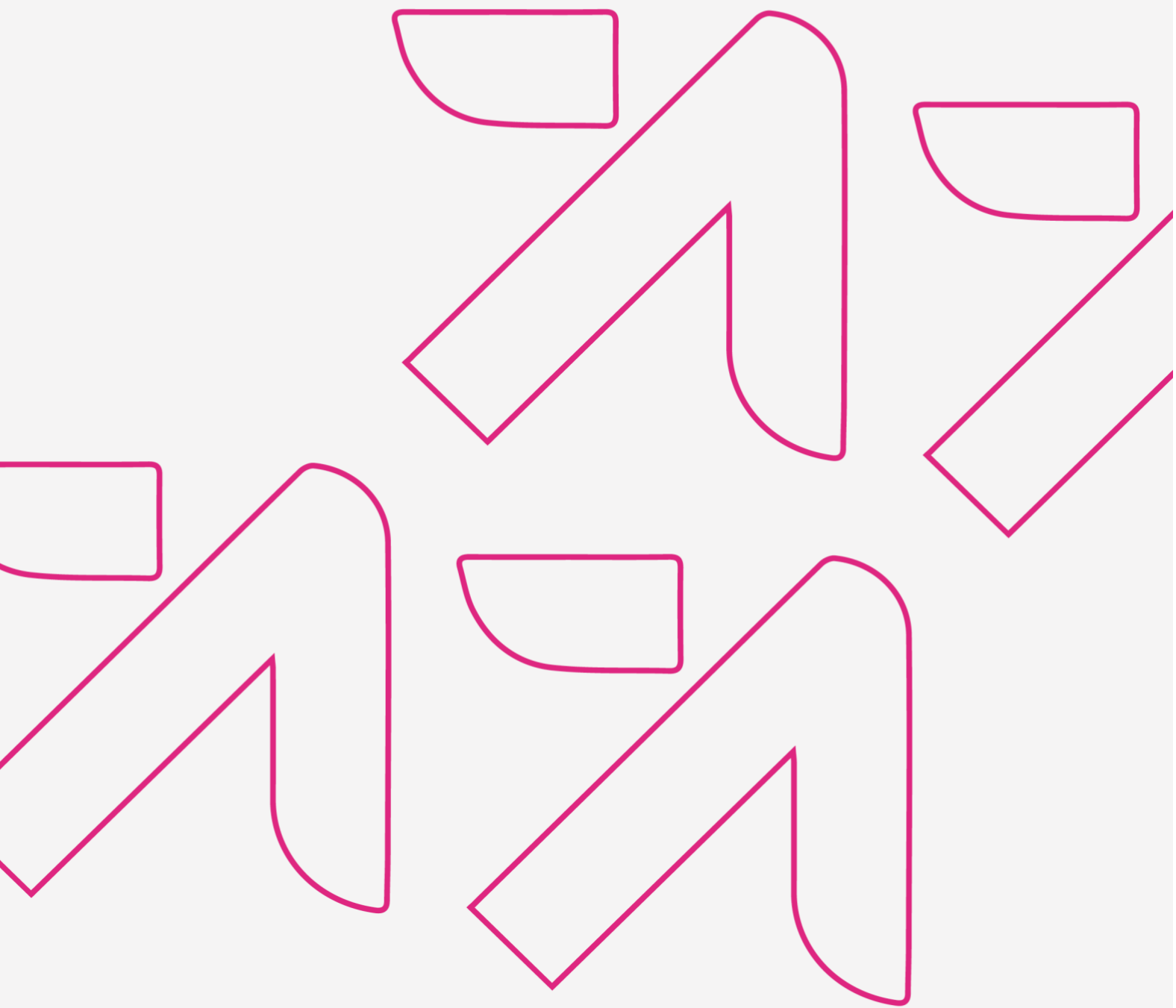




Máster de

Ciberseguridad Hacking Ético

[Módulo Bastionado de Redes y Sistemas]

Curso académico 2026/2027 - Edición Presencial

UT5. Gestión de identidades y accesos (IAM)

Encaje en el curso 2026/2027: esta unidad desarrolla el RA2 (controlar el acceso de las personas, tema 3) y el RA3 (gestionar credenciales, temas 4 y 5).

1. Objetivo de IAM

La gestión de identidades y accesos (IAM, *Identity and Access Management*) garantiza que cada persona, servicio o dispositivo tenga una identidad única, se autentique de forma fiable y acceda únicamente a lo que necesita, durante el tiempo que lo necesita.

Hoy la mayoría de intrusiones no «rompen» nada: entran con credenciales válidas robadas, reutilizadas o mal protegidas. Por eso se dice que la identidad es el nuevo perímetro.

2. Principios fundamentales

2.1. Mínimo privilegio

Cada identidad recibe los permisos estrictamente necesarios para su función, ni uno más.

2.2. Necesidad de conocer

Tener un cargo no da acceso a todo: se accede solo a la información que la tarea requiere.

2.3. Segregación de funciones

Ninguna persona debe poder completar sola un proceso crítico. Quien solicita un pago no lo aprueba; quien desarrolla no despliega en producción sin revisión.

2.4. Trazabilidad

Toda acción debe poder atribuirse a una identidad concreta. Esto descarta las cuentas compartidas.

2.5. Denegación por defecto

Lo que no está permitido de forma explícita, está denegado.

3. Identidades de usuarios

3.1. Ciclo de vida

La identidad nace, cambia y muere con la relación laboral:

- **Alta:** creación de la cuenta con los permisos del puesto, nunca copiando los de un compañero.
- **Cambio:** al cambiar de puesto se añaden los permisos nuevos y se retiran los antiguos. Si no, se acumulan.

- **Baja:** deshabilitar la cuenta el mismo día de la salida y revocar sesiones, tokens y accesos remotos.

3.2. Buenas prácticas

- Una cuenta por persona; nada de cuentas genéricas tipo «recepción» o «prácticas».
- Cuenta de administración separada de la cuenta de uso diario.
- Directorio centralizado (Active Directory, Entra ID, LDAP) como única fuente de verdad.
- Inicio de sesión único (SSO) para reducir contraseñas y poder cortar el acceso desde un solo sitio.
- Revisión periódica de cuentas huérfanas, inactivas o de personal externo.

4. Identidades de servicios

Aplicaciones, scripts, tareas programadas y máquinas también tienen identidad. Suelen ser las cuentas más olvidadas y, a menudo, las más privilegiadas.

4.1. Riesgos habituales

- Contraseñas que no caducan y que nadie ha cambiado en años.
- Permisos de administrador «para que funcione».
- Credenciales escritas en scripts, ficheros de configuración o repositorios de código.
- Cuentas personales usadas como cuentas de servicio.

4.2. Cómo gestionarlas

- Una cuenta por servicio, con permisos mínimos y sin inicio de sesión interactivo.
- En Active Directory, cuentas de servicio administradas (gMSA), que rotan la contraseña solas.
- Secretos en un gestor (HashiCorp Vault, Azure Key Vault, AWS Secrets Manager), nunca en el código.
- En cloud, roles e identidades administradas en lugar de claves de larga duración.
- Rotación periódica y registro de quién usa cada credencial.

5. Autenticación

5.1. Factores

- **Algo que sabes:** contraseña, frase de paso, PIN.
- **Algo que tienes:** móvil con aplicación TOTP, llave de seguridad, tarjeta, certificado.
- **Algo que eres:** huella, rostro.

5.2. Contraseñas hoy

Las recomendaciones actuales (NIST SP 800-63B, CCN-CERT) priorizan la longitud sobre la complejidad:

- Frases de paso largas mejor que contraseñas cortas con símbolos.
- Comprobar que la contraseña no aparece en listas de filtradas.
- No forzar cambios periódicos sin motivo; sí cambiarla de inmediato si hay sospecha de filtración.
- Gestor de contraseñas corporativo para no reutilizar.
- En el servidor, almacenarlas con funciones lentas y con sal (Argon2id, bcrypt, yescrypt).

5.3. Autenticación multifactor (MFA)

No todos los segundos factores protegen igual:

Método	Resistencia al phishing	Comentario
SMS o llamada	Baja	Vulnerable a duplicado de SIM; solo como último recurso
Notificación push	Media	Usar con coincidencia de número para evitar la fatiga de MFA
TOTP (aplicación)	Media	Buen equilibrio; el código se puede robar en una web falsa
FIDO2 / passkeys	Alta	La credencial está ligada al dominio real; es el objetivo
Certificado o tarjeta	Alta	Habitual en administración pública y entornos regulados

5.4. Ataques contra la autenticación

Fuerza bruta, *password spraying* (pocas contraseñas contra muchos usuarios), relleno de credenciales filtradas, phishing con proxy inverso que roba la sesión ya autenticada y fatiga de MFA.

6. Control de acceso

6.1. Modelos

- **DAC (discrecional):** el propietario del recurso decide quién accede. Es el de los permisos clásicos de ficheros.
- **MAC (obligatorio):** lo decide una política central que el usuario no puede cambiar (SELinux, niveles de clasificación).

- **RBAC (por roles):** los permisos se asignan a roles y las personas a roles. Es el estándar en empresa.
- **ABAC (por atributos):** decide según atributos del usuario, el recurso y el contexto (departamento, hora, dispositivo, ubicación).

6.2. RBAC bien hecho

- Roles definidos por función del puesto, no por persona.
- Pocos roles y claros; si hay más roles que empleados, algo falla.
- Permisos sobre grupos, nunca sobre usuarios sueltos.
- Recertificación: cada cierto tiempo, el responsable confirma que su equipo sigue necesitando lo que tiene.

6.3. Acceso condicional

La decisión no depende solo de quién eres, sino de desde dónde y con qué: dispositivo gestionado y al día, ubicación habitual, nivel de riesgo del inicio de sesión. Es la base práctica de Zero Trust.

7. PAM (Privileged Access Management)

Las cuentas privilegiadas (administradores de dominio, root, administradores de cloud, cuentas de servicio potentes) son el objetivo final de cualquier atacante. PAM es el conjunto de controles específicos para ellas.

7.1. Controles principales

- **Bóveda de credenciales:** las contraseñas privilegiadas se guardan cifradas y se rotan tras cada uso.
- **Acceso justo a tiempo (JIT):** el privilegio se concede bajo petición y caduca solo; nadie es administrador de forma permanente.
- **Equipo de salto o bastión:** la administración se hace desde un punto controlado, no desde el puesto con el que se lee el correo.
- **Grabación de sesiones** y registro de comandos.
- **Cuentas de emergencia** (*break glass*): guardadas a buen recaudo, vigiladas y probadas de vez en cuando.

7.2. En el día a día

- Linux: sudo con reglas concretas por comando, nunca ALL para todos.
- Windows: Windows LAPS para el administrador local y modelo de niveles (un administrador de dominio no inicia sesión en puestos de usuario).
- MFA obligatorio en cualquier acceso privilegiado, sin excepciones.

8. IAM en cloud

En la nube todo es una llamada a una API autenticada, así que IAM es el control de seguridad más importante.

- Proteger la cuenta raíz: MFA fuerte, sin claves de acceso y sin uso diario.
- Roles con credenciales temporales en lugar de usuarios con claves permanentes.
- Federación con el directorio corporativo: una sola identidad y una sola baja.
- Políticas sin comodines: evitar Action: "*" y Resource: "*".
- Herramientas que detectan permisos sin usar o accesos públicos (por ejemplo, IAM Access Analyzer en AWS).
- Fallos típicos: claves subidas a un repositorio, roles que permiten escalar privilegios y recursos compartidos con «cualquiera».

Esta parte se amplía en la UT7.

9. Auditoría de accesos

9.1. Qué registrar

- Inicios de sesión correctos y fallidos.
- Altas, bajas y cambios de permisos o de pertenencia a grupos privilegiados.
- Uso de cuentas privilegiadas y de emergencia.
- Cambios en la configuración de MFA o de las políticas de acceso.

9.2. Qué revisar

- Cuentas inactivas o sin propietario.
- Inicios de sesión desde países u horarios inusuales, o «viajes imposibles».
- Muchos fallos seguidos (fuerza bruta) o pocos fallos repartidos entre muchas cuentas (*spraying*).
- Permisos acumulados que ya no corresponden al puesto.

10. Buenas prácticas

- Una identidad por persona y por servicio; cero cuentas compartidas.
- MFA en todo acceso remoto, privilegiado o a datos sensibles; resistente al phishing donde se pueda.
- Mínimo privilegio y acceso justo a tiempo para la administración.
- Bajas el mismo día y revisión periódica de permisos.
- Secretos fuera del código, en un gestor, y con rotación.
- Todo acceso registrado y enviado al sistema central de logs.

Para ampliar

- NIST SP 800-63B: directrices de identidad digital y autenticación.
- Guía CCN-STIC 821 (normas de seguridad en el ENS) y medidas op.acc del Anexo II del ENS (control de acceso).
- CIS Controls v8, controles 5 y 6: gestión de cuentas y de control de acceso.
- FIDO Alliance: funcionamiento de FIDO2 y passkeys.